Lab — Analyse de trafic avec tcpdump

Cours : 420-B01-HU — Surveillance préventive en cybersécurité

Durée prévue : environ 2 h

Environnement : votre VM Kali du cyber range

Mise en situation

Vous êtes analyste au SOC d'un fournisseur de services gérés. Un client, la PME **Ébénisterie Gatineau**, signale un comportement étrange : le poste de l'atelier « rame » depuis ce matin et la comptable a reçu une alerte de son antivirus.

Le technicien sur place a lancé une capture réseau au port miroir du commutateur pendant quelques minutes, le **13 octobre 2026 vers 10 h**. Il vous transmet le fichier `Ebenisterie_Gatineau.pcap`. Vous n'avez **ni Wireshark ni interface graphique** : seulement `tcpdump` et les outils de la ligne de commande.

Votre mission : reconstituer ce qui s'est passé et recommander des mesures.

Plan d'adressage connu du client

Adresse IP	Poste	Rôle
192.168.50.1	Passerelle / pare-feu	Sortie Internet
192.168.50.10	SRV-DC01	Contrôleur de domaine, DNS, intranet
192.168.50.20	SRV-FICHIERS	Serveur de fichiers
192.168.50.21	POSTE-COMPTA	Poste de la comptable
192.168.50.22	POSTE-RH	Poste des ressources humaines
192.168.50.35	POSTE-ATELIER	Poste partagé de l'atelier

Récupérer le lab

```
cd ~
git clone https://github.com/SnailLabs-dev/Labs.git   # ou : git -C Labs pull
cd Labs
ls -l
```

Partie A — Prise en main en direct (≈ 20 min)

Le but est de voir tcpdump capturer **votre propre** trafic avant d'analyser celui d'un autre.

1. Listez les interfaces disponibles et repérez celle qui mène au réseau.

```
ip -br a
sudo tcpdump -D
```

2. Capturez **10 paquets** sur votre interface, sans résolution de noms. Notez ce qui change quand vous retirez l'option `-n`.
3. Dans un **deuxième terminal**, lancez `curl -s http://example.com > /dev/null` pendant que le premier capture **uniquement le DNS et le HTTP**.
   - Quelle requête DNS voyez-vous passer ? Quelle adresse IP est retournée ?
   - Relancez la capture avec `-A` : retrouvez la ligne `Host:` et le `User-Agent` envoyés par curl.
4. Recommencez avec `curl -s https://example.com`. Que voyez-vous de différent avec `-A` ? Pourquoi ?
5. Enregistrez 30 secondes de trafic dans un fichier, puis relisez-le :

```
sudo timeout 30 tcpdump -i <interface> -n -w ma_capture.pcap
tcpdump -n -r ma_capture.pcap | head
```

> La capture en direct exige `sudo`. La **lecture** d'un fichier `.pcap` avec `-r` n'en a pas besoin.

Partie B — L'enquête (≈ 75 min)

Travaillez sur `Ebenisterie_Gatineau.pcap`. Pour chaque question, **notez la commande exacte** que vous avez utilisée : elle compte autant que la réponse.

B1. Vue d'ensemble

1. Combien de paquets contient la capture ?
2. À quelle heure commence et finit la capture ? *(indice : `-tttt`)*
3. Quelle adresse IP **source** émet le plus de paquets ? Est-ce normal pour ce poste ? *(indice : `awk '{print $3}'`, `cut -d. -f1-4`, `sort | uniq -c | sort -rn`)*

B2. Le DNS raconte l'histoire

4. Listez tous les noms de domaine demandés au DNS, avec leur nombre d'occurrences.
5. Un domaine ne ressemble à aucun service connu de l'entreprise. Lequel ? Quel poste l'interroge, et vers quelle adresse IP pointe-t-il ?

B3. Reconnaissance

6. Un poste envoie des requêtes ICMP *echo* à toute une plage d'adresses.
   - Lequel ? Combien de requêtes envoie-t-il ?
   - Quels hôtes répondent ? *(indice : `icmp[icmptype] == icmp-echoreply`)*
7. Le même poste s'attaque ensuite à un serveur en particulier.
   - Quel serveur, et quel type de balayage ? *(regardez les drapeaux TCP)*
   - Combien de ports sont testés ?
   - **Quels ports sont ouverts ?** Justifiez avec le filtre BPF utilisé.
   - Pourquoi l'attaquant envoie-t-il un `RST` juste après chaque `SYN-ACK` ?

B4. Identifiants en clair

8. Une employée se connecte à l'intranet. Retrouvez son **nom d'utilisateur** et son **mot de passe**. *(attention à l'encodage URL : `%21` = ?)*
9. Le poste de l'atelier se connecte au serveur de fichiers par FTP.
   - Quel compte et quel mot de passe utilise-t-il ?
   - Quel fichier télécharge-t-il ? Pourquoi est-ce inquiétant ?
   - Sur quel port passe le **canal de données** ? Montrez le calcul à partir de la réponse `227 Entering Passive Mode (...)`.

B5. Exfiltration et commande-contrôle

10. Certaines requêtes DNS du poste compromis contiennent des sous-domaines étranges, numérotés `0-`, `1-`, `2-`…
    - Reconstituez la chaîne en les mettant dans l'ordre.
    - Elle est encodée en **base32** (en minuscules, sans le bourrage `=`). Décodez-la. *(indice : `tr a-z A-Z`, `base32 -d`)*
    - Quel est le drapeau `FLAG{...}` obtenu ?
11. Le poste communique régulièrement avec un serveur externe sur un port inhabituel.
    - Quels sont l'adresse IP et le port ?
    - À quel **intervalle** se répètent les connexions ? Comment s'appelle ce comportement ?
    - Quel `User-Agent` est utilisé ? Qu'a-t-il de suspect ?
    - Une des réponses du serveur diffère des autres. Que contient-elle ?

B6. Extraire la preuve

12. Créez un fichier `preuve_c2.pcap` contenant **uniquement** les échanges avec le serveur de commande-contrôle. Combien de paquets contient-il ?

Partie C — Rapport (≈ 15 min)

Rédigez un court rapport (une page maximum) qui contient :

- une **chronologie** de l'incident (heure, poste, action) ;
- les **indicateurs de compromission** (IP, domaine, port, User-Agent, comptes) ;
- **trois recommandations** concrètes et priorisées pour le client.

À remettre

- Vos réponses aux questions de la partie B, **avec les commandes utilisées** ;
- le fichier `preuve_c2.pcap` ;
- votre rapport de la partie C.

Aide-mémoire

Option	Effet
`-i eth0`	Interface de capture
`-n`	Pas de résolution de noms ni de ports
`-c 20`	Arrêter après 20 paquets
`-r f.pcap`	Lire un fichier
`-w f.pcap`	Écrire dans un fichier (format brut)
`-A` / `-X`	Afficher la charge utile en ASCII / en hex + ASCII
`-tttt`	Horodatage complet (date et heure)
`-e`	Afficher les adresses MAC
`-v`, `-vv`	Plus de détails sur les en-têtes

Filtres BPF utiles : `host`, `src`, `dst`, `net 192.168.50.0/24`, `port`, `portrange`, `tcp`, `udp`, `icmp`, `and`, `or`, `not`, `tcp[tcpflags] & tcp-syn != 0`, `icmp[icmptype] == icmp-echo`.

Commandes utiles vues au cours 6:

```
tcpdump -nr Ebenisterie_Gatineau.pcap ip | awk '{print $3}' | cut -d. -f1-4 | sort | uniq -c | sort -rn
```

```
tcpdump -nr Ebenisterie_Gatineau.pcap 'udp dst port 53' | awk '{print $8}' | sort | uniq -c | sort -rn
```

> ⚠ Mettez toujours les filtres complexes entre **apostrophes** pour que le shell ne les interprète pas.